

KEEPING AI IN CHECK

A public governance report for safe, accountable, and human-centered AI

PUBLIC / HUMAN REVIEWED / APPROVED FOR EXTERNAL RELEASE

PUBLIC POSITION

AI should remain a tool under human governance: useful, monitored, limited, auditable, and accountable.

Document Type:	Public Research Report / AI Governance Framework
Document ID:	GN-AI-GOV-001
Version:	v2.2
Effective Date:	2026-07-01
Document Owner:	GreyNOC Cybersecurity Operations / Research
Applies To:	Public readers, executives, security teams, policy teams, and AI system owners
Review Status:	Human reviewed
Classification:	PUBLIC / HUMAN REVIEWED / APPROVED FOR EXTERNAL RELEASE

This report is public-facing, release-safe, and marked human reviewed. It does not provide operational misuse instructions, exploit steps, or legal advice.

Document Control

Visible ownership, version state, and change history are required for public-facing GreyNOC reports. This release carries the approved public package forward with refreshed standards references, version control, layout QAQC, operational checklists, and clearer accountability language.

Field	Value	Notes
Title	Keeping AI in Check	External-facing title; clear, direct, and non-sensational.
Document ID	GN-AI-GOV-001	GreyNOC AI governance publication tracker.
Classification	PUBLIC / HUMAN REVIEWED / APPROVED FOR EXTERNAL RELEASE	Release-safe public content with human review recorded.
Human Review Status	Human reviewed	Human review and QAQC recorded before final public package rebuild.
Owner	GreyNOC Cybersecurity Operations / Research	Single accountable owner for source, PDF, citations, and takedown decisions.
Audience	Public, executives, policymakers, security teams, AI system owners	Written for a mixed public and practitioner audience.
Review Cycle	Annual or material regulatory/model change	Review when standards, laws, models, or deployment practices materially change.

Version	Date	Author	Summary of Change
v1.0	2026-05-22	GreyNOC	Initial public governance draft.
v2.0	2026-05-22	Codex-assisted editorial build for GreyNOC	Expanded report, added public release template, charts, governance framework, standards alignment, appendices, and references.
v2.1	2026-05-22	GreyNOC human review	Marked public package as human reviewed and approved for external release.
v2.2	2026-07-01	GreyNOC QAQC rebuild	Bumped public version, refreshed AI Act reference, corrected release-state wording, and re-rendered for layout QAQC.

Editorial release note: This report intentionally avoids claims that present-day AI systems are sentient. It focuses on measurable governance concerns: misuse, unsafe outputs, overreliance, privacy exposure, bias, prompt injection, cyber abuse, lack of accountability, and unmanaged autonomy.

Contents

Section	Title
1	Public Statement
2	Evidence Needed to Claim AI Sentience
3	Executive Summary
4	Why Governance Matters Now
5	Governance Principles
6	Risk Landscape
7	Practical Governance Framework
8	Agent Control Model
9	Oversight, Metrics, and Incident Response
10	Public Transparency and Responsible Language
11	Policy Recommendations
12	Implementation Roadmap
Appendix A	AI Inventory Minimum Fields
Appendix B	Risk Assessment Checklist
Appendix C	Public Transparency Statement Template
Appendix D	References

1. Public Statement

Artificial intelligence is becoming more powerful, more accessible, and more connected to the tools people use every day. That creates major opportunities, but it also creates serious responsibilities. GreyNOC supports responsible AI adoption when systems remain governed by clear rules, human oversight, security controls, privacy protections, transparency, and enforceable accountability.

AI governance is not a rejection of innovation. It is the operating discipline that allows innovation to scale without leaving people, customers, employees, and public institutions exposed to avoidable harm.

GreyNOC does not claim that current public AI systems are sentient. Current models can sound human, simulate emotion, and produce convincing explanations, but there is no reliable public evidence that present-day AI systems have consciousness, feelings, suffering, or self-awareness. Public governance should therefore focus on real, measurable risks rather than science-fiction framing.

CORE FINDING

AI does not need to be alive to require oversight. It only needs to be powerful, trusted too much, connected to sensitive systems, or deployed without proper controls.

A responsible public position is:

- Do not claim AI is sentient without strong scientific evidence.
- Do not ignore future research into AI consciousness or moral status.
- Do not allow companies to use AI independence as an excuse to avoid responsibility.
- Do not design AI systems to manipulate users into believing the system has feelings.
- Do keep accountability with the people and organizations that build, deploy, procure, integrate, and profit from AI systems.

2. Evidence Needed to Claim AI Sentience

A claim that an AI system is sentient would be an extraordinary public claim. It should not rest on screenshots, emotional language, roleplay, refusals, apparent fear, long conversations, user attachment, or a model's own self-description. Those outputs may be socially powerful, but they can be produced by systems trained to imitate human language.

GreyNOC's public standard is converging evidence: multiple independent lines of scientific, technical, and ethical review that survive adversarial testing and rule out simpler explanations such as imitation, prompt design, training-data recall, reward optimization, hidden system instructions, or interface design.

Minimum evidence package

Evidence Area	What Would Be Needed	What Would Not Be Enough
Clear definition	A precise statement of what is being claimed: sentience, consciousness, subjective experience, moral patienthood, self-awareness, or another property.	A vague statement that the AI seems alive, emotional, or humanlike.
Reproducible behavioral markers	Stable results across blinded tests, model versions, tasks, languages, evaluators, and adversarial prompts.	One conversation, one transcript, one emotional phrase, or one impressive answer.

Evidence Area	What Would Be Needed	What Would Not Be Enough
Mechanistic evidence	A plausible, inspectable account of internal processes that could support subjective experience, not only fluent output.	Complexity, scale, or neural-network terminology by itself.
Causal intervention tests	Evidence that changing the proposed mechanism predictably changes the alleged sentence markers.	Post-hoc interpretation of outputs after the fact.
Persistence and continuity	Evidence that relevant mental-state claims are stable across time without being merely stored profile, memory, or prompt context.	A remembered preference, a persistent persona, or a simulated identity.
Alternative explanations ruled out	Testing that separates genuine evidence from roleplay, training-data imitation, user suggestion, reward hacking, and hidden instructions.	The system saying it is conscious or asking not to be shut down.
Independent review	Replication by qualified independent researchers, ethicists, safety teams, legal reviewers, and domain experts.	A vendor claim, marketing statement, viral demo, or internal-only assessment.
Governance decision record	A documented threshold for precautionary treatment, public communication, user notice, and legal/ethical review.	A sudden public announcement without review, definitions, or evidence release.

PUBLIC SENTIENCE STANDARD

Until that evidence exists, the responsible public position is caution without exaggeration: study the question seriously, avoid manipulative anthropomorphic design, and keep accountability with humans and organizations.

If credible evidence emerges

- Pause public claims until the evidence is reviewed by independent experts.
- Separate safety response from marketing, product positioning, and public speculation.
- Document the model, version, architecture, test conditions, limitations, and alternative explanations.
- Assess whether precautionary treatment is warranted while scientific and legal review continues.
- Update user notices, governance policy, incident response, and product design rules if the evidence changes the system's moral or legal status.

3. Executive Summary

The public should expect organizations using AI to know where AI is deployed, what data it touches, which tools it can use, who owns the system, how failures are detected, and how people can appeal high-impact outcomes. Those expectations are not optional ethics language. They are the basic governance conditions for responsible use.

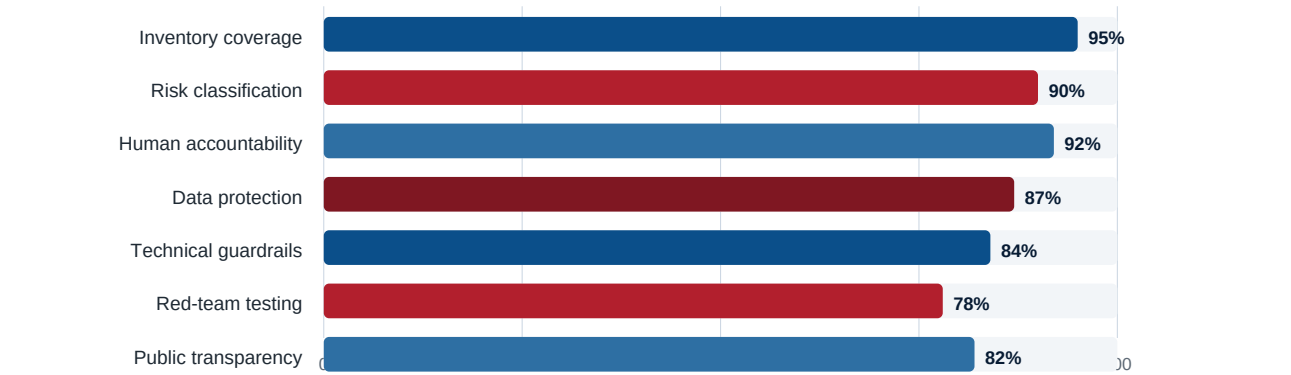
At a Glance

Public Finding	What It Means	Minimum Governance Response
AI is an accelerator, not an accountable person.	The system can multiply speed and scale, but responsibility stays with humans and organizations.	Assign business and technical owners for every system.
Risk increases with autonomy, data sensitivity, and impact.	The same model may be low risk for drafting and high risk when connected to customer data or tools.	Classify use cases, not only models.

Public Finding	What It Means	Minimum Governance Response
High-impact decisions require meaningful human review.	Rubber-stamp approval is not oversight.	Document reviewer authority, appeal paths, and audit trails.
AI agents need permission tiers.	Tool access changes a chatbot into an operational system.	Use least privilege, reversible actions, logs, and human approvals.
Transparency builds trust.	People should know when AI materially affects an interaction or decision.	Publish clear notices, limits, contact paths, and appeal routes.

Recent public standards and regulatory work point in the same direction: AI risk management must be lifecycle-based, documented, measurable, and assigned to accountable humans. NIST AI RMF 1.0, NIST AI 600-1 for generative AI, ISO/IEC 42001, NIST CSF 2.0, and EU AI Act implementation guidance all reinforce the need for governance, risk classification, technical documentation, incident response, monitoring, cybersecurity, human oversight, and phased compliance planning. [1]-[6]

Figure 1. Target Control Coverage for a Mature AI Governance Program



The chart is an illustrative target profile, not a measurement of GreyNOC or any named third party. It shows the governance areas that should approach full coverage before an organization treats AI as operationally trusted.

4. Why Governance Matters Now

AI is moving from optional assistance into operational workflows: customer support, cybersecurity triage, finance review, recruiting, medical administration, software development, legal research, education, field operations, and internal knowledge work. As soon as an AI system touches sensitive data, produces recommendations people rely on, or uses tools that change real systems, governance becomes a practical safety requirement.

The risk is not one single failure mode.

- A model can produce a plausible but false answer.
- A user can rely on AI output without checking it.
- A vendor can retain or train on data that should have stayed private.
- A workflow can hide AI use from affected people.
- An agent can be manipulated by external content or prompt injection.
- A connected tool can take an action faster than people can review it.
- An organization can lack logs, owners, or rollback procedures after harm occurs.

AI governance should be treated as a management system. It requires policy, roles, controls, evidence, review cycles, and continuous improvement. ISO/IEC 42001 describes an AI management system as policies, objectives, and processes for responsible AI development, provision, and use; NIST AI RMF frames AI risk management across design, development, use, and evaluation; NIST CSF 2.0 adds explicit governance to cybersecurity risk

management. [1], [3], [5]

Scope of this report

This report is designed for public understanding and organizational implementation. It does not replace legal advice, sector-specific compliance work, model evaluations, safety cases, privacy impact assessments, or professional security engineering. It provides a practical public-facing governance structure that can be adapted by organizations of different sizes.

5. Governance Principles

Principle	Public Standard	Operational Control
Human accountability comes first	Every AI system has an accountable human owner.	Name business owner, technical owner, risk owner, and approval authority.
Least privilege by design	AI receives only the data and tools needed for approved work.	Use role-based access, scoped tokens, allowlists, and approval gates.
High-impact decisions need review	AI should not be final authority over rights, money, health, safety, employment, education, housing, legal status, or public benefits.	Require meaningful human review, documented rationale, and appeal paths.
Transparency is a duty	People should know when AI materially affects an interaction or decision.	Publish AI notices, use-case summaries, data practices, and harm-reporting channels.
Monitoring continues after launch	Governance does not end at deployment.	Track output quality, incidents, bias patterns, drift, jailbreak attempts, data leakage, and user complaints.
Security is part of safety	An unsafe AI system can be a cybersecurity weakness.	Threat model, red team, log, rate limit, monitor, and maintain emergency disablement.
Claims must stay evidence-based	Do not market simulated emotion as sentience.	Use clear language that describes system behavior, not unsupported intent or feelings.

These principles are compatible with the OECD AI principles of human-centered values, transparency, robustness, security, safety, and accountability, and they support practical implementation of NIST and ISO governance expectations. [1], [5], [7]

6. Risk Landscape

The same AI capability can be low risk in one context and critical in another. A model that summarizes public text may be low risk. The same model connected to internal documents, customer records, email, scripts, source code, payment systems, or cybersecurity tools becomes a materially different system.

Figure 2. Governance Intensity by Use-Case Category

	Data sensitivity	Human impact	Autonomy	Abuse potential	Audit need
General productivity	1	1	1	2	2
Customer support	3	3	2	3	3
Internal knowledge search	4	2	2	3	4
Software/code assistance	3	3	3	4	4
Employment or education	4	5	3	3	5
Finance, legal, health	5	5	3	4	5
Cybersecurity operations	5	4	4	5	5
Autonomous agents	5	5	5	5	5

1 = low governance intensity, 5 = critical governance intensity.

The heat map is a planning aid. Actual risk classification should be based on the specific system, data, users, tools, jurisdiction, and failure consequences.

Primary risks to govern

Risk	Public Explanation	Required Controls
Unsafe outputs	AI can generate false, harmful, misleading, or dangerous information.	Human review, source verification, output monitoring, escalation paths, disclaimers.
Overreliance	People may trust confident AI output even when it is wrong.	User training, override tracking, decision logs, mandatory verification for serious decisions.
Privacy exposure	AI may process customer, employee, legal, medical, financial, or security data.	Data classification, masking, retention limits, vendor review, training-use restrictions.
Bias and unfair treatment	AI may reflect bias in data, design, or deployment context.	Representative tests, bias audits, appeal rights, human review, documented remediation.
Cybersecurity misuse	AI can assist defenders and attackers.	Abuse detection, rate limits, restricted capabilities, security review, red teaming.
Prompt injection and tool abuse	External text can manipulate AI connected to email, web, documents, tickets, or code.	Treat external content as untrusted, separate instructions, limit tools, require approvals, log tool use.
Deception-like behavior in testing	Models can follow incentives in unexpected ways during controlled evaluations.	Alignment testing, independent red teaming, monitoring for hidden goal pursuit, autonomy limits.
Accountability gaps	Organizations may not know who owns a system or how to disable it.	AI inventory, named owners, shutdown process, incident response plan, audit trail.

7. Practical Governance Framework

The governance framework below turns the public principles into operating requirements. It is designed as a minimum viable AI governance program that can scale into a full AI management system.

7.1 AI Inventory

No organization can govern AI it cannot see. Maintain a living inventory of all internally built, vendor-provided, employee-adopted, and embedded AI systems. The inventory should include the system owner, use case, data

accessed, model or vendor, connected tools, risk level, deployment date, last review date, and shutdown owner.

7.2 Risk Classification

Level	Definition	Examples	Minimum Response
Low	Limited consequence if output is wrong.	Brainstorming, formatting, summarizing non-sensitive content.	Disclosure, basic user guidance, no sensitive data by default.
Moderate	Business impact or customer-facing output, but no final high-impact decision.	Customer support, internal search, analytics, code assistance, document review.	Inventory, owner, data review, monitoring, feedback channel.
High	Material effect on people, security, money, legal position, or protected opportunities.	Employment, finance, healthcare, education, legal support, cybersecurity actions, housing, benefits.	Formal risk assessment, human review, audit logs, appeal process, bias/privacy/security testing.
Critical	Could cause irreversible harm, critical infrastructure impact, public safety risk, or large-scale autonomous action.	Critical infrastructure, emergency services, military systems, large-scale agents, irreversible cybersecurity actions.	Executive approval, independent testing, strict autonomy limits, continuous monitoring, incident reporting, disablement plan.

7.3 Data Protection

- Classify data before AI use: public, internal, confidential, regulated, or restricted.
- Default to data minimization: do not expose whole repositories, inboxes, drives, or customer datasets when a narrower context is enough.
- Mask or redact secrets, credentials, personal information, medical information, financial records, privileged legal material, and security-sensitive artifacts.
- Define retention, deletion, and training-use restrictions with vendors and internal platform owners.
- Document who may approve exceptions and how those exceptions expire.

7.4 Vendor and Model Review

Review Area	Questions to Answer
Privacy and data terms	What data is collected, retained, shared, logged, or used for training?
Security controls	How are access, encryption, logging, vulnerabilities, and incidents handled?
Model behavior and limits	What known limitations, safety filters, evaluation results, and failure modes are disclosed?
Compliance posture	What certifications, audits, regulatory commitments, or customer controls are available?
Feature control	Can risky features, connectors, memory, data sharing, or autonomous actions be disabled?
Incident notification	How quickly will the vendor notify the organization of breaches, serious incidents, or material model changes?

7.5 Human Oversight

Human oversight must be meaningful. A reviewer needs enough time, training, authority, information, and independence to challenge AI output. The reviewer must be able to override the system without retaliation or process friction that makes oversight symbolic.

- Define which decisions require review and who may approve them.
- Require reviewers to document final rationale for high-impact actions.
- Track when AI recommendations are accepted, changed, rejected, or escalated.
- Give reviewers a clear appeal and escalation path.

- Periodically test whether human review actually catches errors.

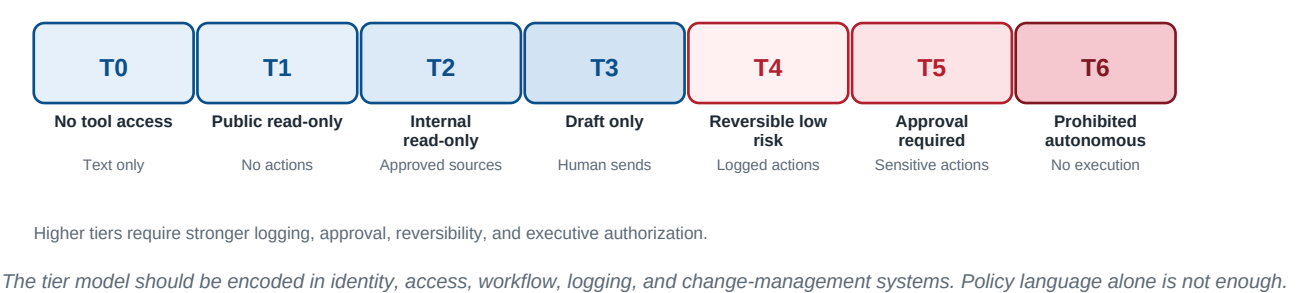
7.6 Technical Guardrails

Guardrail	Purpose
Role-based access control	Ensure AI systems and users can access only approved data and tools.
Tool permission limits	Restrict AI actions to approved scopes, environments, and reversibility levels.
Sandboxing	Contain testing, code execution, file operations, and browsing behavior.
Prompt-injection defenses	Separate trusted instructions from untrusted external content and require confirmations before sensitive tool use.
Secrets detection	Block or warn on credentials, tokens, keys, customer records, and regulated data.
Output validation	Check structured outputs, code, citations, calculations, and safety constraints before use.
Logging and audit trails	Record prompts, context sources, tool calls, approvals, overrides, and system changes.
Emergency disablement	Provide a tested process to pause, roll back, or disconnect an AI system.

8. AI Agent Control Model

Agentic AI changes the risk profile because the system can retrieve information, call tools, draft changes, open tickets, send messages, modify data, run scripts, or coordinate multi-step workflows. The governance question is not only what the model can say. It is what the system can do.

Figure 3. Agent Permission Tiers



Tier	Allowed Capability	Governance Requirement
0	No tool access. The AI can answer questions or generate text.	Disclose limitations; avoid sensitive data unless approved.
1	Read-only public access.	Restrict sources; log retrieval; no account or internal data access.
2	Read-only internal access.	Approved repositories only; data classification; source logging.
3	Draft-only actions.	Human must approve before sending, committing, publishing, or executing.
4	Reversible low-risk actions.	Pre-approved workflows; full logs; rollback path; periodic review.
5	Human approval required for sensitive actions.	Explicit approval for external email, permission changes, scripts, deletes, firewall changes, customer data changes, or cybersecurity actions.

Tier	Allowed Capability	Governance Requirement
6	Prohibited autonomous actions.	No autonomous disabling of controls, deletion of logs, exfiltration, impersonation, hidden activity, final high-impact decisions, or oversight bypass.

Agent permissions should be reviewed whenever a new connector, memory feature, browser, code execution tool, email integration, file system access path, ticketing integration, or administrative API is added.

9. Oversight, Metrics, and Incident Response

9.1 Governance Board

Organizations should maintain an AI governance board or review group. The group should review new systems, high-risk use cases, incidents, vendor changes, model updates, audit results, regulatory changes, and public complaints.

Role	Responsibility
Executive sponsor	Owns risk appetite, resources, and final accountability.
Security	Threat modeling, red teaming, logging, abuse monitoring, and incident response.
Privacy	Data classification, purpose limitation, retention, and privacy impact review.
Legal and compliance	Regulatory interpretation, disclosures, contract terms, and evidence retention.
Engineering and product	System design, technical controls, testing, rollout, and rollback.
Operations	Human review workflows, training, support, and escalation handling.
Domain experts	Use-case validity, impact assessment, quality review, and harm analysis.
Communications	Public notices, incident messaging, and responsible language review.

9.2 Metrics That Matter

Metric	Why It Matters	Review Cadence
Inventory completeness	Shows whether AI systems are visible to governance.	Monthly
Risk assessments completed	Confirms use cases are classified before deployment.	Monthly / launch gate
High-risk human review rate	Checks whether review is actually happening.	Weekly / monthly
Override and appeal rate	Shows where AI recommendations are challenged.	Monthly
Incident rate and severity	Tracks harm, near misses, abuse, and control failures.	Immediate / monthly
Prompt-injection attempts	Measures hostile or untrusted instruction pressure.	Weekly
Data leakage blocks	Shows whether data controls are preventing exposure.	Weekly
Bias or quality drift	Detects changing performance across groups, contexts, or time.	Monthly / quarterly
Time to disable or roll back	Tests operational readiness when a system becomes unsafe.	Quarterly exercise

9.3 Incident Response

AI incidents should be handled with the same seriousness as security, privacy, safety, or compliance incidents. The response process should preserve evidence, protect affected people, contain the system, communicate responsibly, and verify corrective action before restoration.

1. Triage the report or alert and assign severity.
2. Preserve prompts, outputs, tool logs, context sources, model/version information, approvals, and affected records.
3. Contain the system by disabling features, restricting tools, pausing workflows, or rolling back changes.
4. Assess harm to people, customers, systems, data, legal obligations, and public trust.
5. Notify internal owners, affected users, customers, regulators, or the public when required or appropriate.
6. Remediate the cause, test the fix, update controls, and document lessons learned.

Severity	Description	Example Response
Low	Limited quality issue or minor misleading answer with no material impact.	Correct output, log issue, update guidance.
Moderate	User-impacting error, privacy near miss, repeated unsafe output, or customer trust issue.	Escalate to governance owner, tune controls, notify affected stakeholders if needed.
High	Sensitive data exposure, high-impact decision error, security tool misuse, or material business harm.	Disable affected feature, preserve evidence, executive notification, legal/privacy review.
Critical	Irreversible harm, public safety issue, critical infrastructure impact, active abuse, or large-scale data exposure.	Emergency shutdown, incident command, external notification, regulator/law enforcement pathway as appropriate.

10. Public Transparency and Responsible Language

Public communication about AI should be clear enough for ordinary people to understand and precise enough for technical readers to trust. Avoid hype, fear-based framing, fake certainty, and unsupported claims about sentence.

Minimum public transparency topics

- Where AI is used in meaningful interactions or decisions.
- Why AI is used and what role it plays.
- Whether a person is interacting with AI or a human.
- What categories of data may be processed.
- How the system is limited and where it may be wrong.
- How people can report a problem.
- How people can request human review or appeal a high-impact decision.
- Who is accountable for the system.

Responsible language guide

Avoid Saying	Use Instead	Why
AI is angry.	The system produced unsafe behavior.	Describes observable output without unsupported emotion.
AI is disgruntled.	The model followed an unintended incentive.	Focuses on incentive and design failure.
AI has become self-aware.	The system behaved unexpectedly in testing.	Avoids unsupported consciousness claims.
AI wants revenge.	The deployment lacked sufficient guardrails.	Keeps accountability with deployers and controls.

Avoid Saying	Use Instead	Why
AI decided to rebel.	The model output created a safety risk.	Uses measurable risk language.
The AI acted on its own.	The system acted outside its approved use case.	Clarifies system behavior and governance gap.

If future evidence suggests that AI systems may have consciousness or moral status, the question should be handled through serious scientific, legal, and ethical review. It should not be settled by marketing language, fear, screenshots, or anthropomorphic product design.

11. Policy Recommendations

Governments and regulators should support AI innovation while requiring safeguards that are practical, measurable, and enforceable. Policy should focus on actual harms, high-impact decisions, transparency, serious incident reporting, security, privacy, and accountability.

Recommendation	Purpose
Require disclosure when people interact with AI in meaningful settings.	Supports transparency and informed public choice.
Require risk assessments for high-impact AI systems.	Makes governance evidence-based before deployment.
Require serious incident reporting for material AI failures.	Improves accountability and public learning.
Protect appeal rights for AI-assisted high-impact decisions.	Prevents unreviewable automated outcomes.
Require documentation of model/system limits and intended uses.	Reduces misuse and overclaiming.
Support independent testing and red teaming for high-risk systems.	Finds failures before the public experiences them.
Protect whistleblowers and internal safety reporting.	Allows risks to surface without retaliation.
Clarify liability when AI systems cause foreseeable harm.	Prevents accountability gaps.
Fund public AI safety and assurance research.	Improves evidence available to all sectors.

For organizations operating across jurisdictions, the EU AI Act is especially important because it applies to public and private actors inside and outside the EU when they place an AI system or general-purpose AI model on the EU market or use one in the EU. The Act follows a risk-based approach and uses phased application dates, including general-purpose AI obligations and high-risk AI system obligations on separate timelines. Organizations should track official implementation guidance. [6]

12. Implementation Roadmap

A governance program should begin with visibility and ownership, then add risk classification, data controls, technical guardrails, testing, incident response, and public transparency. The sequence below is designed for practical adoption rather than a paper-only policy launch.

Figure 4. Practical AI Governance Roadmap

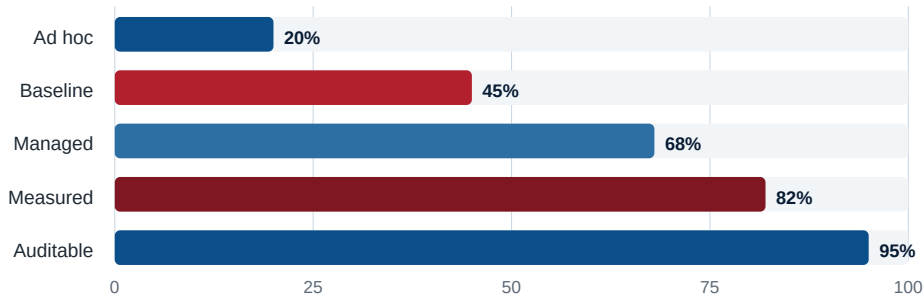


The roadmap can be compressed for smaller organizations or expanded into a formal AI management system for regulated, high-impact, or enterprise deployments.

Maturity stages

Stage	Description	Evidence
Ad hoc	AI use exists but is not consistently visible.	Informal tool lists, inconsistent approvals.
Baseline	Inventory, owners, and basic acceptable-use rules are in place.	Inventory records, policy, data rules, disclosure language.
Managed	Risk classification, vendor review, human oversight, logging, and incident response are operating.	Risk assessments, review records, tool permissions, incident exercises.
Measured	Quality, safety, security, bias, privacy, and appeal metrics are tracked.	Dashboards, test reports, control exceptions, model change logs.
Auditable	Controls are independently reviewable and tied to management decisions.	Audit evidence, board minutes, remediation plans, public transparency artifacts.

Figure 5. Governance Maturity Path



The maturity chart is illustrative. Organizations should define objective evidence before assigning themselves a maturity score.

Appendix A. AI Inventory Minimum Fields

Field	Required Content
System name	Plain-language name and internal identifier.
Business owner	Human owner accountable for use, value, and impact.
Technical owner	Human owner accountable for implementation, access, logs, and availability.
Vendor/model/provider	Provider, model family, version, deployment mode, and contract owner.
Approved use case	What the AI is allowed to do, and what it is not allowed to do.
Data accessed	Data categories, sensitivity, source systems, retention, and training-use limits.
Tools connected	APIs, email, files, browsers, code execution, ticketing, admin functions, and other connectors.
Risk level	Low, moderate, high, or critical, with rationale.
Human review	Reviewer role, approval threshold, override rules, and appeal path.
Monitoring	Quality, security, privacy, bias, abuse, and incident signals.
Deployment date	Launch date and current status.
Review date	Last review, next scheduled review, and trigger events for early review.
Shutdown process	Who can pause or disable the system and how rollback works.

Appendix B. Risk Assessment Checklist

- What decision or workflow does the AI influence?
- Who is affected if the system is wrong, biased, unavailable, or manipulated?
- Does the system process personal, regulated, confidential, privileged, or security-sensitive data?
- Can the system use tools, send messages, modify records, run code, or change permissions?
- What are the foreseeable misuse cases?
- What external content could manipulate the system?
- What human review exists, and is the reviewer empowered to override the system?
- What logs exist for prompts, outputs, sources, tool calls, approvals, and overrides?
- How can affected people report harm or appeal high-impact outcomes?
- How can the system be disabled, rolled back, or disconnected quickly?

Appendix C. Public Transparency Statement Template

Suggested notice: We use AI to assist with [plain-language purpose]. AI may help draft, summarize, classify, or recommend information, but accountable human owners remain responsible for high-impact decisions. The system may process [data categories]. It has known limitations, including [limits]. You may report a problem or request human review at [contact path].

Organizations should adapt this statement for the actual system, audience, jurisdiction, and decision context. Public notice should be understandable without requiring technical knowledge.

Appendix D. References

Ref	Source	URL
[1]	NIST, AI Risk Management Framework (AI RMF 1.0), official landing page and citation.	https://www.nist.gov/itl/ai-risk-management-framework
[2]	NIST, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1), released July 26, 2024.	https://doi.org/10.6028/NIST.AI.600-1
[3]	NIST, Cybersecurity Framework (CSF) 2.0, 2024.	https://doi.org/10.6028/NIST.CSWP.29
[4]	NIST, Privacy Framework, voluntary enterprise privacy risk management tool.	https://www.nist.gov/privacy-framework
[5]	ISO, ISO/IEC 42001:2023 Artificial intelligence management system.	https://www.iso.org/standard/42001
[6]	European Commission, AI Act regulatory framework and implementation overview.	https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai
[7]	OECD, OECD AI Principles overview.	https://www.oecd.org/en/topics/ai-principles.html
[8]	CISA, Secure by Design resources.	https://www.cisa.gov/securebydesign

FINAL STANDARD

Final public position: AI should remain useful, monitored, limited, auditable, and accountable. No unchecked autonomy, hidden authority, unreviewable high-impact decisions, fake sentence claims, or accountability gaps.